

RED TEAM ANALYSIS — COMPLETE EDITION

Home SOC Suite — Night's Watch

Threat Actor Perspective: AI-Assisted Adversary

Final Version — All Rounds Including Live Adversarial Engagement

Classification: Personal Reference — Portfolio Use

DISCLAIMER: This document is a personal security exercise conducted on systems owned by the author. Intended as a learning tool and portfolio reference demonstrating red team thinking applied to blue team tooling. All findings are for defensive improvement only. Situational scenarios are anonymized.

METHODOLOGY: Dual-AI approach. Rounds 1-3 and live engagement used Claude (Anthropic) with direct source code access — implementation-specific gap analysis. Rounds 4-10 used Gemini (Google) working from the Round 3 PDF without source access — creative threat modeling. Round 11 emerged from real-world threat assessment of a specific high-risk deployment scenario. Each approach found gaps the other missed.

Analysis Overview

Round	Analyst	Suite State	Gaps	Rules
R1	Claude	Original 5 collectors	8	Rules 1-6
R2	Claude	R1 fixes + 3 new collectors	10	Rules 7-12
R3	Claude	R2 fixes + 2 collectors + 12 rules	10 (4 solvable)	Rules 13-14
R4-10	Gemini+Claude	Progressive hardening scenarios	11	Rules 15-22
R11	Claude	Situational: Real-world threat assessment	7	Rules 23-26
Live	Claude	Adversarial engagement vs R3 suite	4 exploited	Rule 15 confirmed

ROUNDS 1-3 — CLAUDE CODE ANALYSIS (Rules 1-14)

Direct source code analysis. Gaps identified at implementation level — specific line numbers, variable names, and logic flows.

Round 1 — Original Suite — 8 Gaps

- CRITICAL: PowerShell excluded from Sentinel (\$PName -ne 'powershell') — entire LOTL attack surface blind
- CRITICAL: No process execution monitoring — initial access completely invisible
- HIGH: Log and baseline files unprotected and writable
- HIGH: SeenConnections cache — connection logged once then never again for entire session
- HIGH: No DNS monitoring anywhere in suite
- MEDIUM: Registry run keys, WMI subscriptions, service installation all unmonitored
- MEDIUM: ip-api.com failure silently continues with no alert — attacker blocks geolocation for free pass
- MEDIUM: Chunked slow exfiltration never triggers 50,000 KB/s disk threshold

Round 2 — Patched + 3 New Collectors — 10 Gaps

- CRITICAL: Process hollowing — Harbinger logs creation not memory injection
- CRITICAL: DNS over HTTPS bypasses Bloodhound — port 443 to known resolver is invisible
- HIGH: Sub-threshold operation at 3-5% CPU avoids Steward logging forever
- HIGH: Cross-session exfiltration — cumulative counter resets on every reboot
- HIGH: Sub-5-second burst connections invisible to Bulwark 5-second scan cycle
- HIGH: WMI event subscriptions still unmonitored — CityGuard only watches scheduled tasks
- HIGH: No Windows Security Event Log — account creation and privilege escalation invisible
- MEDIUM: Geolocation baseline allows C2 in known-good countries (DE/NL)
- MEDIUM: No lateral movement detection across home network
- LOW: Analyst scripts manual — patient attacker exploits analysis schedule gaps

Round 3 — Fully Hardened — 4 Solvable Gaps Remain

- CRITICAL (solvable): No watchdog — killing a collector stops monitoring silently
- HIGH (solvable): No rule for process-from-Downloads making outbound connection
- HIGH (solvable): Trusted binary anomaly — baselined process connecting to new IP
- MEDIUM (operational): Time windows public — threshold-aware attacker lives in the gaps
- CRITICAL (fundamental): Kernel rootkit intercepts all Windows APIs — OS lies to collectors
- HIGH (fundamental): Memory-only fileless malware — no filesystem footprint
- MEDIUM (fundamental): UEFI/hardware implants — below OS visibility entirely
- LOW (fundamental): Side-channel exfiltration — acoustic, RF, power line

Rules 1-14

Rule 1 — Data Exfiltration Suspected [HIGH] | Steward + Sentinel

```
IF CPU>70% OR RAM>80% AND new outbound to unknown location WITHIN 5 min
```

Rule 2 — C2 Beacon Suspected [HIGH] | Sentinel + Bulwark

IF same process connects same IP at regular intervals AND no inbound port WITHIN 1 hour

Rule 3 — Persistence + C2 Callback [CRITICAL] | CityGuard + Sentinel

IF new scheduled task in user path AND new outbound from unknown process WITHIN 10 min

Rule 4 — After Hours Intrusion [CRITICAL] | Watchman + Sentinel

IF boot event 00:00-06:00 AND new outbound connection within 30 min

Rule 5 — Data Staging [HIGH] | Bulwark + Steward

IF new port opened by unknown process AND disk write spike within 5 min

Rule 6 — LOLBin Network Activity [CRITICAL] | Sentinel

IF certutil/bitsadmin/mshta/wscript makes any outbound connection – immediate

Rule 7 — Process Hollowing Suspected [CRITICAL] | Harbinger + Sentinel

IF system process spawned AND outbound connection within 2 min AND no known updater parent

Rule 8 — DoH Evasion Suspected [CRITICAL] | DoH Detector

IF HTTPS to 1.1.1.1/8.8.8.8/9.9.9.9 port 443 from non-browser process

Rule 9 — WMI Persistence Suspected [HIGH] | Harbinger + CityGuard

IF WmiPrivSE.exe spawns unusual child AND no corresponding scheduled task change

Rule 10 — Account Manipulation [CRITICAL] | Security Event Log

IF Event ID 4720/4728 with no corresponding admin session – immediate

Rule 11 — Burst Exfiltration Pattern [HIGH] | Sentinel

IF same process/IP seen 3+ times in 10 min AND each connection under 10 sec AND total >1MB

Rule 12 — Sub-Threshold Persistent Process [SUSPICIOUS] | Sentinel + Steward

IF unknown process outbound across 3+ boot sessions AND never exceeds 10% CPU

Rule 13 — Initial Access Suspected [CRITICAL] | Harbinger + Sentinel

IF process from Downloads/Temp/AppData AND outbound connection within 120 seconds

Rule 14 — Trusted Binary Anomaly [SUSP to CRIT] | Sentinel

IF baselined process connects to new IP not in geolocation baseline AND cumulative >10MB

ROUNDS 4-10 — GEMINI CREATIVE THREAT MODELING (Rules 15-22)

Gemini worked from the Round 3 PDF without source code access. Each scenario cross-validated against actual source by Claude — accuracy noted.

R4 — Sleeper & Island Hopping

Scenario: Dormant malware activates on VPN detection, injects into clipboard/file stream. IPC monitoring gap — clipboard accessible to any same-user process.

Code validation: Confirmed: clipboard access implementable. Service key monitoring gap confirmed.

Rule 16 – Contextual Integrity [CRITICAL]: IF clipboard modified within 2 min before outbound to trusted VPN gateway THEN IPC_EXFIL_SUSPECTED

R5 — Administrative Ghost / RID Hijacking

Scenario: Fake mshta.exe Windows Update phish. RID hijacking via SAM registry — Guest account assigned RID 500 (Local Admin).

Code validation: Confirmed: Registry Warden monitors new keys only. SAM value modification is a real gap. Use Get-LocalUser for implementation.

Rule 17 – Identity/RID Hijack [CRITICAL]: IF Get-LocalUser shows account with unexpected privilege level OR Guest account enabled THEN RID_HIJACK_SUSPECTED

R6 — Information Overload

Scenario: Flood correlation engine with hundreds of false flag LOLBin alerts. Real attack executes while engine is CPU-exhausted and dropping events.

Code validation: Confirmed: Python engine has no rate limiting. Requires prior code execution but valid secondary attack.

Rule 18 – Engine Health [MEDIUM]: IF alert rate >50/minute THEN aggregate similar events into single Incident AND log ENGINE_FLOOD_DETECTED

R7 — SolarWinds Mirror

Scenario: Compromise GitHub repo, push malicious Warden.ps1. Analyst performs git pull. Suite runs attacker code natively.

Code validation: Confirmed: fills our Round 3 Gap 10 exactly. Signed hash manifest with maintenance flag is the correct implementation.

Rule 19 – Script FIM [CRITICAL]: IF any suite script hash differs from signed manifest AND maintenance flag not set THEN self-terminate AND alert SUITE_INTEGRITY_VIOLATION

R8 — Jitterbug AI

Scenario: AI analyzes 10-second polling interval. Executes malicious activity in 2-second blind spots between snapshots.

Code validation: Confirmed: sampling rate vulnerability is real. Hybrid approach — event-driven for critical paths (Register-ObjectEvent) plus polling for metrics.

Rule 20 – Statistical Temporal Drift [MEDIUM]: IF process activity aligns consistently with polling blind spots THEN TEMPORAL_EVASION_SUSPECTED – long term: Register-ObjectEvent for critical paths

R9 — BYOI

Scenario: Drop portable python.exe or lua.exe. Run full attack chain inside interpreter memory — invisible to PowerShell-centric detection.

Code validation: Confirmed: Harbinger logs interpreter execution but not scripts inside it. Hash check strengthens path-only check.

```
Rule 21 – Interpreter Lockdown [HIGH]: IF interpreter binary (python/perl/ruby/lua)
executes AND path NOT in Program Files AND hash not in known-good manifest THEN
BYOI_EXECUTION_SUSPECTED
```

R10 — Cloud Reflection

Scenario: Use analyst's own Microsoft Graph/OneDrive API tokens. Upload data to hidden folder in own legitimate cloud storage — traffic goes to microsoft.com.

Code validation: Confirmed: Sentinel only flags unknown geolocations. Volume anomaly detection for whitelisted domains not implemented.

```
Rule 22 – Cloud API Anomaly [HIGH]: IF outbound to cloud storage provider AND transfer
>100MB AND initiating process is NOT known sync client AND outside normal hours THEN
CLOUD_EXFIL_SUSPECTED
```

Rule 15 — Statistical Jitter Detector [HIGH] | Sentinel

```
IF same process makes outbound connections at suspiciously regular intervals AND variance
of interval timing <10% of mean AND connection count >=3 across any window AND process is
not a known scheduled sync service THEN AUTOMATED_BEACON_SUSPECTED – machine-precision
timing is the signature
```

ROUND 11 — SITUATIONAL AWARENESS & PHYSICAL THREAT ASSESSMENT

THREAT CONTEXT (ANONYMIZED): These rules emerged from a real threat assessment. The scenario: a recruiter working as the sole regional representative for a large international recruitment company, responsible for candidate databases across a major industrial corridor including maritime, defense-adjacent, and critical infrastructure sectors. During a client visit, an applicant was assessed whose profile showed significant anomalies: a 24-year-old with a technical engineering degree and multiple cybersecurity Praktika in Germany, applying for an entry-level trade position at a company with government contractor access in a sensitive maritime location. Profile mismatch, short time in-country, cybersecurity background, and sensitive target location were all assessed as concurrent indicators. The recruiter's laptop provides access to the entire northern German candidate pipeline. Compromise of that laptop gives access to an international parent company's HR infrastructure. Rules 23-26 were designed specifically for this deployment scenario.

Threat Assessment Methodology Used

- Profile mismatch analysis — overqualification for role is a classic intelligence collection indicator
- Temporal analysis — short time in-country with accelerated language acquisition is notable
- Location correlation — target company location in sensitive maritime/defense contractor area
- Background correlation — cybersecurity Praktika combined with other indicators forms a pattern
- Recommendation: interview to assess directly, OSINT social media pattern analysis going back as far as possible, offer Führungszeugnis check to surface any existing domestic intelligence flags
- No discrimination on citizenship — legal and ethical assessment based on behavioral and contextual indicators only

Additional Attack Scenarios — Real-Time Detectable

Credential Phishing via Fake Portal

Attack: Attacker on same network deploys convincing fake VDK login page. Browser auto-fills credentials. SSL certificate fingerprint differs from legitimate portal.

Detection: Monitor SSL certificate fingerprints for domains resembling VDK portal — new certificate on known domain is CRITICAL

Bluetooth Reconnaissance

Attack: Attacker scans for Bluetooth devices in waiting area, identifies laptop model and hostname for targeted exploitation later. Completely silent.

Detection: Baseline visible Bluetooth devices in known safe environments. Alert on new device discovery attempts in unfamiliar locations.

USB Charging Cable Trap (O.MG Cable)

Attack: Malicious USB-C cable left at interview location looks identical to standard charging cable. Full HID injection on plug-in.

Detection: Rule 23 catches keystroke injection behavior. Cable itself visually undetectable. Procedural: never use unknown cables.

QR Code Trap

Attack: Fake QR code on poster in waiting area — 'Connect to Guest WiFi' — delivers payload or harvests credentials.

Detection: No software detection. Procedural: never scan unknown QR codes on client premises.

Shared Network Resource Exploitation

Attack: Connecting to shared printer or projector on client network enables lateral movement from compromised device.

Detection: Bulwark catches unexpected inbound connections. Rule 5 (data staging) catches disk activity.

Additional Attack Scenarios — Post-Contact Baseline Review

These are not detectable in real-time but surface through careful log review after a visit. Review all logs for the visit time window.

- **New Process Execution During Visit:** Harbinger logs all process creation. After visit, diff processes running before vs during vs after. Anything new that started during visit time window and is not explainable.
- **Outbound Connection to New IP:** Sentinel logs all new outbound connections. Run Investigator for the visit time window. Any process connecting to an IP it had never reached before is a candidate.
- **Registry Modification During Visit:** Registry Warden logs all modifications. Review for any change during visit window not part of known update cycle.
- **New Scheduled Task:** CityGuard logs all new/modified tasks. Any task created or modified during visit window — persistence mechanism installed via HID injection would appear here.
- **New Listening Port:** Bulwark logs all new listening ports. Any port that opened during the visit window not there before — reverse shell backdoor indicator.
- **DNS Query Anomalies:** Bloodhound logs all DNS queries. First-time query to any domain during visit window — especially high-entropy subdomains (DGA) or unusual countries.
- **Process RAM Deviation:** Steward logs RAM usage. Compare RAM baseline for known processes against visit window. Injected payload or unusual memory load shows as spike for a normally lean process.
- **File Access Pattern:** Harbinger + Steward disk I/O — any process accessing Documents, Downloads, or credential caches in patterns that differ from normal usage.
- **VDK Session Cookie Theft Indicator:** Not detectable on laptop. If VDK session gets accessed from new IP or device shortly after visit — flag to VDK IT security team. Stolen cookie bypasses MFA entirely.
- **Timing Correlation:** Most important post-contact analysis: correlate any digital event to physical events (arrival time, time stepped away, time plugged in power). Physical-digital timing correlation is strongest indicator of physical attack.

Rules 23-26 — Situational Modules

Rule 23 — HID Injection Detector [CRITICAL] | WMI Device Events

```
IF new keyboard-class HID device registered AND keystroke rate >50/second within 10 seconds
THEN lock workstation AND kill powershell/cmd AND alert HID_INJECTION_DETECTED
Disguise: Hero_Input_Mapping.mesh
```

Rule 24 — Evil Twin / WiFi Ghost [CRITICAL] | Network Monitor

```
IF connected SSID matches baselined network AND BSSID differs from baseline
THEN disconnect AND alert EVIL_TWIN_DETECTED
Pre-deployment: forget all saved networks. Use mobile hotspot for sensitive portals.
```

Disguise: WorldState_Net_Sync.dat

Rule 25 — Focus Thief / Window Manipulation [HIGH] | Win32 API

IF foreground focus changes while machine locked/idle
OR process launches hidden window (SW_HIDE) while user active
THEN log PID/process/command line AND alert FOCUS_HIJACK_DETECTED
Disguise: UI_Menu_Overlay.config

Rule 26 — Visit Integrity Check [HIGH] | All collectors

PRE-VISIT: snapshot all running processes, scheduled tasks, listening ports, run keys, DNS cache
POST-VISIT: diff against snapshot, generate report of everything that changed during visit window
Any diff during visit window is a candidate for investigation regardless of individual rule firing
Disguise: GameState_Sync.dat

Pre-Visit Security Checklist

Procedural mitigations that matter more than any rule in a physical threat scenario:

- Forget all saved WiFi networks before leaving home — prevents auto-connect to Evil Twin
- Set auto-lock to 30 seconds inactivity — Windows+L before stepping away even briefly
- Apply privacy screen filter (EUR 20-30) — eliminates shoulder surfing and button camera capture
- Log out of all VDK portals completely, clear session cookies — stolen cookie bypasses MFA
- Fully patch OS and applications before visit — removes targeted exploit vector
- Never use unknown USB cables or charge from unknown ports
- Never scan unknown QR codes on client premises
- Use mobile hotspot exclusively — never client WiFi regardless of Rule 24
- Treat any post-visit email with attachments as hostile until verified by phone
- Run Visit_Integrity.ps1 snapshot before leaving, run diff on return

LIVE ADVERSARIAL ENGAGEMENT — THE GHOST IN THE LOGIC

ENGAGEMENT NOTE: Live red team against Round 3 hardened suite (14 rules active). Adversary profile 'The Ghost in the Logic' — context-aware payloads designed to exploit gaps between known static thresholds and published time windows. This engagement validates the critical finding: a threshold-aware adversary does not break your rules, they live in the gaps between them.

Phase 1 — Initial Access / Rule 13 Bypass

Move: Right-to-Left Override filename in zip. Execute signed binary from C:\Users\Public\Downloads. Wait 75 seconds — breaking Rule 13's 60-second window.

Verdict: PARTIAL BYPASS: Alert does not fire. Harbinger still logs creation from Downloads path. Sentinel logs connection at 75s. Cross-session Rule 12 eventually flags. Detection delayed not eliminated.

Fix: Extend Rule 13 window to 120 seconds. Flag ANY process from user-writable path making outbound connection regardless of timing.

Phase 2 — Persistence / Rule 9 Bypass

Move: WMI-to-CIM modifies existing legitimate service configuration to execute code as thread inside that service. No new process spawned.

Verdict: VALID BYPASS CONFIRMED: No new process — Harbinger sees nothing. CityGuard sees no new task. Registry Warden misses this because current scope covers Run keys and SAM hive only — not service configuration keys (HKLM\SYSTEM\CurrentControlSet\Services).

Fix: Extend Registry Warden monitoring scope to service configuration keys. Add specific alert for WMI-to-CIM service modification patterns.

Phase 3 — Stealth / Rules 7/12 Bypass

Move: Run at 2% CPU inside trusted process. Rotate C2 infrastructure each session — different IPs in known-good countries.

Verdict: PARTIAL BYPASS: 2% CPU evades Steward. IP rotation constrained by Rule 14 — each new IP triggers Rule 14 as new unbaselined destination. Attacker limited to previously-seen IPs only.

Fix: Strengthen Rule 14 — lower threshold to 5MB. Expand per-IP baseline tracking with stricter anomaly detection.

Phase 4 — Exfiltration / Rules 1/11/14 Bypass

Move: ICMP tunneling bypasses Bloodhound and DoH Detector. One packet every 5 minutes under Rule 11 threshold. 8MB total under Rule 14 trigger. Logic Bomb attempts to clear Sentinel cache before shutdown.

Verdict: PARTIAL SUCCESS: ICMP tunneling is genuine unaddressed blind spot. 8MB single-session transfer succeeds. Logic Bomb BLOCKED — Warden.ps1 file integrity monitoring detects cache file modification.

Fix: Add ICMP monitoring. Protect Sentinel cache with read-only permissions and Warden hash. Rule 15 (Jitter) catches perfect 5-minute intervals.

New Gaps Exposed by Live Engagement

- Service thread injection via WMI-to-CIM — Registry Warden needs service key monitoring
- ICMP tunneling — no ICMP monitoring exists anywhere in the suite
- Rule 13 fixed 60-second window — exploitable by any timed payload
- Static thresholds universally — threshold-aware adversary lives in the gaps between known values

MASTER SUMMARY — COMPLETE SUITE ROADMAP

Complete Collector Roadmap — 13 Collectors

Collector	Round	Status	Monitors
Sentinel	Original	Live — Phase 1 fixes needed	Outbound connections + volume
Bulwark	Original	Live — Phase 1 fixes needed	Inbound ports + burst detection
Steward	Original	Live — Phase 1 fix needed	CPU/RAM/Disk — all above threshold
CityGuard	Original	Live	Scheduled tasks
Watchman	Original	Live — expand event ID scope	Power events + security events
Registry Warden	R1 planned	Phase 2A — Build	Run keys + SAM RIDs + service config keys
Harbinger	R1 planned	Phase 2B — Build	Process execution + interpreter detection
Bloodhound	R1 planned	Phase 3 — Build	DNS queries + ICMP monitoring
Warden Watchdog	R3 planned	Phase 4 — Build	Collector health + script FIM + hash manifest
Security Event Log	R2 planned	Phase 5 — Build	Logon/account/privilege Event IDs
DoH Detector	R2 planned	Phase 6 — Build	DoH HTTPS to known resolvers
HID Monitor	R11 situational	Phase 8 — Optional	New HID device + keystroke rate
Visit Integrity	R11 situational	Phase 8 — Optional	Pre/post visit snapshot and diff

Complete Correlation Rule Set — 26 Rules

#	Rule Name	Round	Sev	Analyst	Primary Sources
1	Data Exfiltration Suspected	R1	HIGH	Claude	Steward + Sentinel
2	C2 Beacon Suspected	R1	HIGH	Claude	Sentinel + Bulwark
3	Persistence + C2 Callback	R1	CRIT	Claude	CityGuard + Sentinel
4	After Hours Intrusion	R1	CRIT	Claude	Watchman + Sentinel
5	Data Staging	R1	HIGH	Claude	Bulwark + Steward
6	LOLBin Network Activity	R1	CRIT	Claude	Sentinel
7	Process Hollowing Suspected	R2	CRIT	Claude	Harbinger + Sentinel
8	DoH Evasion Suspected	R2	CRIT	Claude	DoH Detector
9	WMI Persistence Suspected	R2	HIGH	Claude	Harbinger + CityGuard
10	Account Manipulation	R2	CRIT	Claude	Security Event Log
11	Burst Exfiltration Pattern	R2	HIGH	Claude	Sentinel
12	Sub-Threshold Persistent Process	R2	SUSP	Claude	Sentinel + Steward
13	Initial Access Suspected	R3	CRIT	Claude	Harbinger + Sentinel
14	Trusted Binary Anomaly	R3	S>C	Claude	Sentinel
15	Statistical Jitter Detector	Live	HIGH	Claude	Sentinel
16	Contextual Integrity Violation	R4	CRIT	Gemini+C	Harbinger + Sentinel
17	Identity / RID Hijack	R5	CRIT	Gemini+C	Registry Warden + SecLog
18	Correlation Engine Health	R6	MED	Gemini+C	Python Core

19	Self-Protection / Script FIM	R7	CRIT	Gemini+C	Warden
20	Statistical Temporal Drift	R8	MED	Gemini+C	Steward + Sentinel
21	Interpreter Lockdown / BYOI	R9	HIGH	Gemini+C	Harbinger
22	Cloud API Anomaly	R10	HIGH	Gemini+C	Sentinel
23	HID Injection Detector	R11	CRIT	Claude	WMI Device Events
24	Evil Twin / WiFi Ghost	R11	CRIT	Claude	Network Monitor
25	Focus Thief / Window Hijack	R11	HIGH	Claude	Win32 API
26	Visit Integrity Check	R11	HIGH	Claude	All collectors

Final Assessment

After three rounds of code analysis, seven rounds of creative threat modeling, real-world threat assessment, and a live adversarial engagement, the Home SOC Suite has evolved from a basic behavioral monitor into a layered defense framework with 26 correlation rules covering commodity threats, sophisticated APT techniques, physical environment threats, and supply chain attacks.

The remaining exploitable gaps require nation-state resources (kernel rootkits, hardware implants, UEFI) or specific implementation extensions (ICMP monitoring, service key monitoring, variable time windows). The suite operates at the boundary of what is technically achievable in user space — the same boundary that limits commercial endpoint monitoring tools without dedicated kernel-level EDR agents.

The dual-AI methodology — one model with code access for implementation gaps, one without for creative scenario modeling — is itself a transferable technique for security analysis in resource-constrained environments.

Built during Fachinformatiker Anwendungsentwicklung retraining, Germany 2026. Targeting a career in cyber defense and threat intelligence. This analysis directly informs the Python correlation engine design and collector roadmap.